Microsoft

Azure Key Vault Managed HSM

Backup, Restore, and Disaster Recovery Strategy

Author: Naresh Gupta (Senior Consultant)

This guide outlines a backup, restore, and disaster recovery strategy for **Azure Key Vault Managed HSM** in **GCC High, GCC and Commercial** environments, offering both conceptual guidance and a practical runbook to safeguard Microsoft 365 Customer Key assets and ensure compliance.

Objective

Ensured Key Continuity
Contoso's plan guarantees encryption keys are safe and available during any cloud region outage, enabling swift restoration in a secondary region

Government-Grade Compliance
Built on Azure Government cloud to meet FedRAMP High, HIPAA, and DoD requirements with FIPS 140-3 Level 3 validated hardware

Cost-Effective Resilience
Cold-standby approach uses daily backups instead of dual HSMs, achieving RTO in a few hours and RPO ≤ 24 hours

Robust Compliance Alignment
Contoso's solution operates in a FedRAMP High cloud with FIPS 140-3 Level 3 HSMs, preserving key sovereignty and meeting HIPAA and DoD security mandates

Guaranteed Data Continuity
Even in a regional Azure outage, Contoso can restore its encryption keys within hours, ensuring Microsoft 365 data stays accessible and encrypted by customer-managed keys

Cold-Standby Efficiency
Using a single active HSM and regular backups in a second region, Contoso avoids the cost of a constant backup HSM while still meeting key recovery objectives in a disaster

Overview and Key Objectives

Contoso's encryption key infrastructure is built on Azure Key Vault Managed HSM (Hardware Security Module), a highly secure cloud HSM service that protects the cryptographic keys used for Microsoft 365 Customer Key across Exchange Online, SharePoint/OneDrive, and Microsoft Teams. Deployed in the GCC High environment, where Azure Government is used, this solution meets stringent compliance requirements such as FedRAMP High and other government regulations. Azure Government provides a physically isolated, US-only cloud environment accredited at the FedRAMP High impact level, ensuring that Contoso's sensitive data and keys are handled in accordance with federal security standards. The Managed HSM itself uses FIPS 140-3 Level 3 validated hardware, providing one of the highest levels of cryptographic module security available in the cloud. This combination enables Contoso to maintain sole control over encryption keys as required by regulatory frameworks (key sovereignty), while using a cloud service certified for government workloads.

The purpose of this strategy is to present a comprehensive backup, restore, and disaster recovery plan for Contoso's Azure Managed HSM, in a format suitable for both executive stakeholders and technical implementers. For executives, this ensures that critical business data in Microsoft 365 remains accessible and secure even during a major Azure region outage, mitigating risk of data loss or downtime. The value of implementing this Managed HSM DR plan is business continuity: by safeguarding encryption keys, Contoso ensures uninterrupted access to protected emails and files in Exchange Online, SharePoint, OneDrive, and Teams, even in worst-case scenarios.

This approach directly supports Contoso's compliance obligations, including HIPAA for healthcare data and DoD (Department of Defense) security requirements for government contracts, by ensuring encryption keys are always available under Contoso's control. The plan aligns with FedRAMP High\[CP-9] contingency planning controls and NIST 800-171/CMMC requirements for data recovery. In summary, this Managed HSM backup and recovery strategy provides Contoso with a cost-effective, compliant, and reliable method to maintain control and availability of cryptographic keys under all circumstances.

≤ 24 hours	Few hours
Recovery Point Objective (RPO)	Recovery Time Objective (RTO)
Max key data loss timeframe based on daily full backups	Time to restore keys and resume encryption operations

Strategic Approach

To balance cost and availability, Contoso's design does not use a continuously replicated "active/active" HSM pair. Instead, it relies on a cold-standby approach. Under normal operations, a single primary Managed HSM instance in one Azure Gov region holds all production keys with no secondary HSM pre-provisioned. Regular backups of this HSM's full key set are taken and stored securely in an Azure Storage container in a different Azurdfgdfgdfgsgsgsgfe Government region. If a disaster such as a region-wide outage occurs, rendering the primary HSM unavailable, Contoso will rapidly provide a new Managed HSM in the secondary region and restore the latest backup onto it. This newly restored HSM then serves as the key source for all dependent services. Once the primary region is recovered, Contoso has the option to fail back to resume normal operations in the original region.

This strategy avoids the cost and complexity of always maintaining two active HSMs, while still meeting Contoso's Recovery Time Objective (RTO) and Recovery Point Objective (RPO) targets for encryption keys. RPO is determined by the backup frequency (e.g. daily full backups, meaning a potential maximum data loss of up to 24 hours of key changes). RTO is defined by the time to stand up a new HSM, restore the Security Domain and backups, and update applications; through regular drills, Contoso refines this process to ensure the RTO meets business needs (typically on the order of a few hours).

While Azure Managed HSM offers a preview feature for multi-region replication (active/active HSM clusters), Contoso's current strategy opts for the cold-standby approach to avoid the complexity and expense of running dual HSMs in parallel, while still achieving acceptable recovery times through well-orchestrated procedures and automation. The trade-off is a slightly higher RTO compared to active/active, but this is mitigated by rigorous planning and testing.

This document provides a two-part structure serving both audiences: a Whitepaper (Conceptual Overview) covering architecture, compliance considerations, and key benefits; and an Implementation Guide with detailed step-by-step procedures, checklists, Azure CLI and PowerShell commands, validation steps, and post-disaster actions.

Solution Architecture and Key Components

Single-Region HSM with On-Demand DR

In Contoso's Azure Government cloud environment, the primary Managed HSM is deployed in a single region and serves as the sole custodian of all active encryption keys for Microsoft 365 Customer Key. There is **no second HSM running in parallel** (no real-time multi-region replication). Instead, the **disaster recovery architecture** is based on *on-demand provisioning*.

Primary Managed HSM (Source)

A single Managed HSM instance (single-tenant HSM cluster) operates in the primary Azure Gov region. It stores all of Contoso's Customer Key material for **Exchange Online, SharePoint/OneDrive, and Teams** data encryption policies. The Managed HSM is configured with **soft-delete and purge protection** enabled (required for all Managed HSMs; soft delete is always on, and purge protection is turned on during provisioning). Keys in the HSM are RSA HSM-protected keys with no set expiration to avoid unexpected loss of access. The HSM service provides high availability within the region through its cluster of HSM partitions but **does not natively protect against a full regional outage** — hence the need for a robust DR plan.

Backup Storage in Secondary Region

HSM backups are stored in an **Azure Storage account** located in a **separate Azure region** (e.g. a geographically distant US Gov region for resilience). This storage account holds the periodic backup files (blobs) containing the entire HSM state (keys, attributes, roles, etc.) and is configured with appropriate security:

- A **Blob Storage container** dedicated to HSM backups, with a data retention policy (e.g. keeping 90 days of backups) to meet compliance requirements
- **Private endpoints** or network restrictions to ensure only authorized networks or services can access the backup data
- A **User-Assigned Managed Identity (UAMI)** used by the HSM service for seamless access to backup storage, granted the **Storage Blob Data Contributor** role on the backup storage account, allowing HSM to write backups and perform restores without needing storage keys or SAS tokens

Disaster Recovery (DR) Region HSM (Provisioned On-Demand)

No HSM exists in the secondary region until a DR scenario occurs. If a disaster affects the primary region, Contoso will quickly set up a Managed HSM instance in the secondary region. This HSM will be configured with **purge protection** enabled and networking settings (such as private endpoints and firewall rules) like the primary, to integrate into Contoso's environment immediately. Initially, this HSM is empty and in a "*Not Activated*" state.

Architecture (Conceptual)

Under normal operations, Contoso's primary Managed HSM (in Region A) securely stores all keys. Regular full backups are taken (e.g. daily) and stored in an encrypted form in the backup Storage Account located in Region B. No HSM is running in Region B during normal

operations, but the backup storage ensures that if Region A goes down, the latest key data is available in Region B.

When a region-wide outage or disaster occurs in Region A, Contoso initiates the DR process:

- **Provision a New HSM in Region B.** This new HSM (the *DR target*) is created in Region B to replace the failed primary. It comes up in a "pending" state until the Security Domain is loaded.
- **Restore Security Domain.** Contoso's security team uses their offline-stored Security Domain file and recovery key fragments to upload a *Security Domain* to the new HSM, re-establishing the HSM's identity and enabling it to accept the backups.
- **Restore Latest Backup to New HSM.** The team restores the most recent full backup from the Storage Account in Region B to the newly activated HSM, transferring all key material, key metadata, and HSM access control configurations (RBAC roles) into the new HSM.
- **Cutover and Application Reconfiguration.** The final step is re-pointing applications and services to use the new HSM in Region B, including updating the Data Encryption Policies (DEPs) for each workload and re-running the **M365 Customer Key onboarding service** to validate and enable the new keys.

This entire architecture leverages Azure's supported features (backup/restore and security domain management) rather than any unsupported or custom solution, designed specifically for **Azure Government Cloud** deployment:

- **FedRAMP High Alignment:** All components (Managed HSM, Azure Storage, Azure Active Directory, etc.) reside in Azure Government, audited for FedRAMP High and DoD Impact Level 4/5 compliance. The architecture aligns with NIST SP 800-53 Contingency Planning controls CP-9 and CP-10.
- **Data Sovereignty:** Managed HSM ensures that **all cryptographic operations and key material remain under customer control**, with key data staying within U.S. datacenters.
- **Regulatory Compliance:** The solution supports obligations under healthcare regulations like **HIPAA/HITECH** by maintaining encryption of sensitive data at rest, with customer-controlled keys reinforcing **Zero Trust** principles and strict access control.

Pre-Disaster Preparation and Readiness

Successful recovery from an HSM outage **depends on thorough preparation**. Contoso has established a set of prerequisites and **readiness checklists** to ensure all necessary elements are in place **before** any disaster strikes.

1. **Licensing & Subscriptions**
   Office 365 E5 licenses with Customer Key entitlement, and at least two Azure subscriptions under the same tenant for redundancy

2. **Managed HSM Configuration**
   Primary HSM deployed and activated with soft-delete and purge protection enabled; diagnostic logging and metrics enabled for auditing

3. **Security Domain Offlined**
   Security Domain file and quorum RSA key pairs (e.g. 3 of 5) downloaded and stored securely in at least two separate offline locations

4. **Backup Storage Ready**
   Secondary region storage account with dedicated blob container, UAMI access, private endpoints, and retention policy configured

5. **Daily Backup Schedule**
   Automated full HSM backups daily ensuring RPO ≤ 24 hours; selective key backups available for critical keys

6. **Access Roles Assigned**
   Managed HSM Administrator and Backup roles granted to designated recovery operators; M365 service principals granted Crypto Service Encryption User role

7. **Key URIs Documented**
   Inventory of all key URIs and their associated workloads maintained, with Availability Key policy (Keep/Remove) documented for each DEP

Licensing & Subscriptions

Contoso must verify that its Microsoft 365 tenants have the required **Office 365 E5 licenses**, which include Customer Key entitlement. At least **two Azure subscriptions** must exist under the same Microsoft Entra (Azure AD) tenant, as Microsoft 365 Customer Key requires storing two encryption keys in different subscriptions for redundancy. The subscription IDs should be recorded in the runbook.

Managed HSM Configuration

The primary Managed HSM resource must be deployed and **activated** in the Azure Gov region designated as the primary. It should have **soft-delete (on by default for HSM) and purge protection** enabled to prevent permanent loss of keys. Diagnostic **logging and**

metrics should be enabled on the HSM for auditing purposes. If HSM's firewall is enabled, it must be configured to allow **Trusted Microsoft Services** so that Azure's own services (like backup) can connect if needed.

Security Domain Backup

The Managed HSM's **Security Domain** must be downloaded and secured offline. The Security Domain represents the cryptographic keys that protect the HSM's contents (it is separate from the key material but required to restore that material). Contoso has generated a set of **quorum RSA key pairs** (e.g. 3 of 5 keys needed for quorum) used to download the Security Domain at HSM initialization. The **Security Domain blob (restore_blob.json)** and the associated private key shares are stored securely in at least two separate offline locations (e.g. secure vaults or hardware devices) to ensure availability during a disaster.

Backup Infrastructure

An **Azure Storage Account** (General-purpose v2) is set up in the **secondary region** to hold HSM backups, configured with a **Blob Container** dedicated to HSM backups, appropriate **access controls** (HSM's UAMI has **Storage Blob Data Contributor** permission), **network and encryption settings** (private endpoints or "Allow trusted Microsoft services" enabled), and a **retention policy** (e.g. keep 90 days of backups). **Cross-region replication** of the storage account can be considered for additional resiliency.

Backup Schedule (RPO Considerations)

A regular backup schedule is defined. By default, Contoso performs a **full HSM backup daily** to ensure an RPO of 24 hours or better. If keys are extremely critical (for example, the root keys for Exchange Online), **selective key backups** may be done more frequently (e.g. hourly) to reduce the potential data loss window for those items. Each full backup operation creates a uniquely named folder (e.g. mhsm-\-YYYYMMDDHHMMSS) in the storage container to represent that recovery point.

Roles and Access Control

Proper role-based access is established for Contoso's HSM operations:

Role	Description / Purpose
Managed HSM Administrator	Full administrative control of the HSM (key creation, deletion, management), required for overall management and disaster recovery operations. Assigned only to designated recovery operators
Managed HSM Backup	Specialized role enabling backup and restore actions on the HSM; required for performing backup and restore operations during normal operations and disaster recovery
Managed HSM Crypto Service Encryption User	Role granted to Microsoft 365 service principals (Exchange, SharePoint/OD, Teams via MDEP), allowing those services to use HSM's keys for encryption/decryption operations without key export permissions

These roles enforce **separation of duties** and secure key usage. Only **trusted Contoso admins** hold the **Administrator** and **Backup** roles, while Microsoft 365 services are locked to

the **Crypto Service Encryption User** role, meaning they can use Contoso's keys for encryption but **cannot extract them**.

Documentation of Key References

Contoso maintains an up-to-date inventory of all key URIs and their associated workloads. For each Microsoft 365 Data Encryption Policy (DEP), the **Key URI** in use is documented along with whether an **Availability Key** is configured as a temporary fail-safe if the primary key is inaccessible. Contoso's policy is to use the Microsoft-provided availability key only temporarily; the DR plan is designed to **restore the keys before the availability window expires** due to sovereignty concerns.

This **DR Readiness Checklist** should be reviewed and updated regularly. Particularly in a GCC High environment, where external support may be limited due to security constraints, preparation is key. Microsoft's best practices for key recovery emphasize the importance of secure key backups, documented recovery procedures, and periodic testing.

Backup and Recovery Strategy

Regular Backup Operations

Contoso's Managed HSM backup strategy is designed to meet both operational needs and compliance requirements.

Full Backups

A **full backup** of the Managed HSM is taken at least **daily**, capturing all keys, key versions, attributes, tags, and the HSM's role assignments as of that point in time. These backups are **point-in-time snapshots** of the entire HSM, enabling complete restoration if needed. By scheduling daily full backups, Contoso sets a baseline **RPO of 24 hours** — meaning, in a worst-case scenario, at most one day's worth of key changes might be lost. In practice, many HSM deployments see infrequent key changes, so a daily backup is usually sufficient to cover new key creation or key rotation activities.

Selective (Key-level) Backups

For especially critical keys or periods of rapid key changes, Contoso can perform **selective key backups** on a more frequent basis (e.g. hourly for certain key sets). This is done using the *per-key backup* capability of Managed HSM (which exports a single key to an encrypted .backup file). Such backups can supplement the full daily backup, effectively shortening the RPO for those keys to an hour or less.

Secure Storage of Backups

All backup files are **encrypted and integrity-protected** by Azure; they can only be used in conjunction with the Security Domain and the same HSM instance or a properly recovered instance. The backup files are stored in the designated Azure Storage container in the secondary region, with access restricted to HSM's **managed identity** or specific authorized users. Optionally, backup files can be periodically downloaded and archived offline for additional safety.

Backup Process Automation

Contoso has automated the backup process using Azure CLI and Azure PowerShell. Using **Azure CLI**, a full backup can be initiated with a single command:

az keyvault backup start --hsm-name "" --storage-account-name "" --blob-container-name "" --backup-folder "mhsm--$(date +%Y%m%d%H%M%S)" --use-managed-identity true

This command triggers the Managed HSM to **create a backup** in the specified storage container, using its managed identity for authorization. The backup-folder is automatically named with a timestamp to uniquely identify each backup set.

With **Azure PowerShell**, comparable cmdlets are available via the *Az.KeyVault* module's **Backup-AzKeyVault** and **Restore-AzKeyVault** cmdlets, which accept similar parameters. Note that the storage URL in Azure Government uses the *.blob.core.usgovcloudapi.net* endpoint.

Retention & Validation: Backups are retained according to Contoso's data retention policy (for instance, keeping the last 30 daily backups and cleaning up older ones). Each backup job's success is logged, and the team monitors Azure Monitor or backup job events to ensure backups complete successfully. Regular test restores (in a non-production environment) are part of the drill exercises to validate that backup files are not corrupted and can be used for restoration.

Security Domain and Recovery Key Management

A unique aspect of Managed HSM (as opposed to standard Key Vault) is the concept of a **Security Domain**. In Contoso's environment, the Security Domain was established when the HSM was first activated. Contoso generated **multiple RSA key pairs** (e.g. 5 key pairs) and defined a **quorum** (e.g. 3 of 5) such that a minimum number of those private keys are required to decrypt and restore the HSM's Security Domain. This mechanism ensures that no single person can compromise the HSM's master wrap key — it requires a group of key holders (m-of-n scheme) to come together to perform a restoration.

The **Security Domain file (restore_blob.json)** was securely exported and **stored offline**. The file itself is encrypted using the public keys of the recovery key pairs, and only the corresponding private keys (in quorum) can decrypt it. Contoso keeps these private key components in **hardware tokens or secure vaults**, distributed across at least two geographic locations for resiliency.

Security Domain Recovery is a prerequisite for any full HSM restoration. In a disaster, after a new HSM is spun up, the **Security Domain upload** must occur before restoring the backup. This effectively **recreates HSM's internal state and unlocks the ability to import the backup data**. Without the original Security Domain, the backup files cannot be used — a crucial security measure to prevent unauthorized restoration of stolen backup files.

GCC High / FedRAMP Considerations

All the above processes are fully supported by **Azure Government (GCC High)**. The Azure CLI and PowerShell commands are the same, with slight differences mainly in endpoints (for example, storage account URLs in Azure Government use *core.usgovcloudapi.net* instead of *core.windows.net*). Azure Managed HSM in GCC High provides the same feature set for

backup and restore as in public Azure, since these capabilities are generally **GA in all regions** where Managed HSM is available.

Notably, the **Managed HSM service in Azure Gov is designed to meet FIPS 140-2/140-3, FedRAMP High, and HIPAA requirements** as part of Microsoft's accreditation. Contoso's approach of offline key control and geo-redundant backups further strengthens compliance with regulations like HIPAA (for ensuring availability of electronic Protected Health Information) and contractual obligations to the DoD.

Disaster Recovery Procedure

If the primary HSM's region suffers an outage or other disaster scenario, Contoso's team will execute the **Managed HSM Disaster Recovery runbook**. The high-level process is outlined below, followed by detailed steps and commands for each phase of recovery.

Step 1

Declare Disaster & Prepare

Confirm primary region is unavailable; assemble DR team, ensure Security Domain files and recovery keys are ready; choose latest valid backup

Step 2

Provision New HSM in DR Region

Create a new Managed HSM in the target Azure Gov region with purge protection enabled; assign UAMI for backup/restore permissions

Step 3

Restore Security Domain

Retrieve the new HSM's exchange key; combine Contoso's quorum of recovery private keys to generate restore_blob.json; upload to new HSM

Step 4

Take an Empty Backup (Anchor)

Perform an 'empty' backup on the new activated HSM as a rollback restore point

Step 5

Full Restore from Backup

Restore the latest full backup from the storage container to the new HSM, bringing in all keys, versions, metadata, and RBAC role assignments

Step 6

Validation

Verify that the new HSM contains expected keys, perform test cryptographic operations, and check that HSM RBAC roles and access policies are intact

Step 7

Reconfigure Applications

Update Microsoft 365 DEPs and application configurations to point to the new HSM's key URIs; run Customer Key Validate and Enable steps

Step 8

Audit & Communication

Monitor M365 audit logs for availability key usage; communicate recovery status and timeline to stakeholders

Step 9

Optional Failback

When original region recovers, optionally provision a new HSM there, restore from current HSM's backup, and redirect applications back

Detailed Recovery Implementation Guide

The procedures below assume that the primary (source) Managed HSM is unavailable due to a disaster and that the team has already completed all **prerequisites and preparation** described in earlier sections.

Initial Assessment and Planning

When a potential HSM-impacting incident is detected (e.g. an Azure region outage or a severe service disruption), Contoso must first confirm the scope: determine that the **Managed HSM in the primary region is indeed inaccessible** or compromised by checking Azure Service Health for the region's status and any official Azure Government advisories.

If the HSM is truly unavailable and likely to remain beyond the acceptable outage window, **declare a disaster** and initiate the DR plan. This may involve internal approval processes and alerting the necessary stakeholders. The team must identify the **most recent known-good backup** from the backup storage (usually the latest daily full backup) and confirm the backup folder name and timestamp. The **Security Domain restoration materials** (restore_blob.json and recovery RSA key shares) must be gathered from secure storage, ensuring personnel who hold the key shares are available.

Provision a New Managed HSM in the DR Region

Using the Azure Portal (in Azure Government) or CLI, **create a new Managed HSM instance** in the predetermined secondary region. Key considerations include:

- **Resource Group & Name:** Use the designated resource group and an appropriate name for the new HSM. The service tier and size should mirror the primary HSM's configuration.
- **Region:** Deploy in the Azure Gov region designated for DR (for example, if the primary is in *US Gov Arizona*, the secondary might be *US Gov Texas* for geographic diversity).
- **Enable Purge Protection:** Turn on purge protection for the new HSM to prevent any accidental or malicious deletion.
- **Assign Managed Identity:** Attach the pre-existing **User-Assigned Managed Identity (UAMI)** to the new HSM resource, ensuring it has access to the backup storage using the same UAMI credentials set up earlier.
- **Network Configuration:** If the primary HSM was using private endpoints, set up a new **Private Endpoint** for the new HSM in the appropriate virtual network/subnet of the DR region and update DNS if necessary.
- **Activation State:** After creation, the new HSM will be in a **"Pending" (not activated)** state because it has no Security Domain yet.

Note: Alternatively, Contoso could choose to **pre-provision an empty Managed HSM in the secondary region** well in advance (keeping it in *NotActivated* state), which would save a few minutes during a disaster by avoiding the creation step, though at additional cost. In the

current strategy, the HSM is created at the time of DR to avoid ongoing costs, accepting a slight increase in RTO.

Security Domain Recovery

With the new HSM deployed and awaiting activation, the next task is to load the Security Domain from the original HSM:

1. **Retrieve the Destination HSM's Exchange Key:** Use Azure CLI or PowerShell to fetch a **Security Domain exchange key** (a public key) from the new HSM via the az keyvault security-domain init-recovery command. This provides a file used to encrypt the Security Domain for upload.
2. **Prepare the restore_blob.json:** Using a secure, offline workstation, combine the original Security Domain package with the required number of **RSA private keys** (from the key custodians) to generate the restore_blob.json file for the Security Domain.
3. **Upload Security Domain to New HSM:** Upload the restore_blob.json to the new HSM using Azure CLI:

az keyvault security-domain upload --hsm-name "" --sd-file restore_blob.json --restore-blob

After a successful upload, the new HSM becomes **activated** and now shares **the same Security Domain as the original (source) HSM**, enabling it to accept the backup data from the source HSM.

Security Note: The Security Domain upload step is the most sensitive part of the process — it effectively **unlocks** the new HSM. Contoso must ensure this operation is conducted on a secure network segment, and that the quorum of recovery key holders follow pre-established procedures. All actions should be closely monitored and logged.

Initial Empty Backup on New HSM (Rollback Anchor)

Before importing the actual data from the source backup, Contoso performs an *initial empty backup* of the newly activated HSM. This serves an important purpose: creating a **rollback point** on the new HSM. In case something goes wrong with the subsequent restore (e.g. an incomplete restores or a corrupt backup file), this initial empty backup allows the option to "revert" the new HSM to this empty state.

az keyvault backup start --hsm-name "" --storage-account-name "" --blob-container-name "" --backup-folder "mhsm--initial-empty-backup" --use-managed-identity true

Restore the Latest Full Backup to the New HSM

Now the core of the recovery: restoring the key material to the new HSM. Contoso uses the **Azure CLI** with the Managed Identity method (preferred, since network connectivity to the storage is set up through private links or service endpoints):

az keyvault restore start --hsm-name "" --storage-account-name "" --blob-container-name "" --backup-folder "" --use-managed-identity true

This operation restores **all keys (and their versions), key attributes, tags, and HSM role assignments** to the new HSM. The new HSM will be an exact replica of the old one's state as of the time of that backup.

If managed identity cannot be used (for example, if network restrictions prevent it), a backup can be restored using a **SAS token** instead, though Contoso prefers the managed identity method to keep all operations internal to Azure Government networks and avoid managing SAS secrets. At this stage, the new HSM in Region B is fully loaded with Contoso's keys and is functionally equivalent to the original HSM.

Post-Restore Validation

After restoration, it is crucial to verify the integrity and completeness of the recovered HSM:

- **Key Inventory Check:** List all keys on the new HSM and ensure the count matches what was on the source HSM using az keyvault key list --hsm-name "<DestHsm>". Spot-check important keys (especially those used by Customer Key in M365) and pay attention to key attributes such as creation and expiration dates.
- **Cryptographic Functions Test:** Perform a simple cryptographic operation (e.g. wrap and unwrap a known plaintext with an HSM-resident key) to confirm the HSM functions correctly after restoration.
- **Access Policies and Permissions:** Verify that the Managed HSM's RBAC settings (role assignments) have been carried over, including HSM Admin, HSM Backup, and Crypto User roles for the M365 services.
- **Monitoring and Alerts:** Check Azure Monitor or the logging solution for any HSM errors or audit events that might indicate issues.

If any problems are discovered during validation — such as missing keys or operation failures — Contoso will **pause** the failover process and evaluate options. The "empty" backup from Step 4 can be used to return to a clean slate if needed, underscoring why maintaining multiple recent backups is important.

Reconfigure Applications and Services

Once the new HSM is confirmed healthy, Contoso updates dependent services and applications to use the new HSM as their key provider:

- **Exchange Online (EXO):** Update the Customer Key DEP with the new key URIs on the DR HSM. Consider the **AvailabilityKeyPolicy** ("Keep" or "Remove") when updating key references.
- **SharePoint Online/OneDrive (SPO/OD):** Similarly update the SharePoint/OneDrive DEP with the new HSM key URIs.
- **Microsoft Teams (via Multi-Workload MDEP):** Update the MDEP key URIs to the new HSM's keys.

After updating the DEPs, run the **Customer Key onboarding service's** *Validate* and then *Enable* steps for each affected service to ensure Microsoft 365 detects the newly available keys and switches encryption to use them.

Other Applications: If any other applications or services were using the Managed HSM's keys, update their configurations (connection strings, key URIs, etc.) to point to the new HSM

name. Because the new HSM has the same Security Domain and keys, the actual key *names* and *versions* remain the same — only the HSM's endpoint (URI) has changed.

DNS and Networking: If HSM is accessed via a **Private Endpoint**, ensure DNS records or IP configurations are updated to point to the new private endpoint.

At this point, the new HSM in the secondary region is live, and all applications are reconfigured. Contoso's data in Microsoft 365 is now encrypted with the keys on the new HSM. End-users experience minimal disruption — the switch of encryption keys is transparent to them. Microsoft 365's *Availability Key* might have been used during the short interval between the primary HSM going down and the restore completing, and the team should check **Microsoft 365 audit logs** for any events indicating its use.

Audit and Stakeholder Communication

With operations restored, Contoso conducts a post-incident review. The IT and security teams verify that all processes were executed according to the runbook and record the **timeline of events** (e.g. time of HSM outage detection, time new HSM provisioned, time of restore completion, time applications cut over) to calculate the actual RTO achieved. If the actual **Recovery Time Objective** was exceeded or close to being exceeded, bottlenecks are identified and improvements planned.

Logs from Azure Monitor, HSM, and Microsoft 365 are reviewed to ensure no anomalies occurred during the process. Any use of the availability key or failed operations is analyzed and reported. **Stakeholders** (both operational teams and executive leadership) are informed of the recovery status, including confirmation that all keys were successfully restored, the time taken, and any interim impacts.

If required, notifications may be sent to regulators or partners, affirming that there was no breach of key sovereignty or data — the keys remained protected and under Contoso's control, and fallback measures were executed in line with compliance commitments.

Optional Failback to Primary Region

If the outage affecting the primary region is resolved, Contoso can choose to *fail back* by performing the same restoration process in reverse: provision a new HSM in the original region, use the **same Security Domain file** to initialize it, perform a **backup of the current DR HSM** and restore it to the new primary-region HSM, then update all configurations back to the primary endpoint. Alternatively, Contoso may continue using the new HSM as the primary going forward and designate a different region as the new DR target, depending on business considerations.

Ongoing Maintenance: Testing and Drills

To ensure the strategy remains effective, Contoso conducts **regular disaster recovery drills** and continuous improvements:

Quarterly DR Drills: On a quarterly basis, the team performs a *practice run* of the HSM restore process in a controlled environment, using a **non-production (test) Managed HSM** to simulate the steps: provision a new test HSM, use the actual Security Domain backup and recovery keys to activate it, restore a recent backup, validate the test HSM matches expected contents, then **decommission** the test HSM upon completion.

Measure and Improve: Each drill is timed and documented. The team updates expected RTO and RPO values based on drill results — for example, if a drill consistently completes in 2 hours, that can be set as the RTO target. Any issues encountered during drills are used to update the runbook. As suggested by Microsoft's best practices, these periodic tests are crucial: they ensure personnel are familiar with the process and that it keeps pace with environmental changes.

Update Documentation: This combined whitepaper and runbook should be maintained as a living document. After each drill or actual incident, steps are refined, contact lists of key holders and operators are updated, backup schedules are adjusted if needed, and any new Azure features for HSMs or backup processes are incorporated. This is not only a best practice but often a compliance requirement — for example, **FedRAMP** and other standards require periodic testing of backup and recovery procedures.

Reference Implementation: Key Configuration Parameters

The following table summarizes the key configuration parameters used in Contoso's Managed HSM DR strategy, along with their purpose. These parameters are typically documented in a separate parameters file (e.g. MHSM-DR-Params.json) so that the DR team can plug them into scripts and commands quickly and accurately during an incident.

Parameter	Description / Purpose
TenantId	Azure Active Directory Tenant ID for Contoso's GCC High environment (GUID identifying the tenant). Used by scripts and documentation for clarity on the context of resources
Source.HsmName / Region / ResourceGroup	The name of the primary Managed HSM instance, its Azure region, and resource group. Identifies the source HSM that is regularly backed up and is subject to potential disaster
Source.Backup.StorageAccountName / BlobContainerName / BackupFolder	Configuration for the Backup Storage Location. StorageAccountName is the storage account in the DR region; BlobContainerName is the specific container; BackupFolder is the most recent backup folder name to restore
Destination.HsmName / Region / ResourceGroup / UserAssignedManagedIdentityResourceId	Settings for the on-demand DR HSM: where to create the new HSM and the UAMI Resource ID to assign backup storage access
SecurityDomain.RestoreBlobFile / QuorumDescription	Path or filename of the Security Domain blob (restore_blob.json) and description of the m-of-n recovery key scheme (e.g. "3 of 5 RSA key holders required")
CustomerKey Key URIs & AvailabilityKeyPolicy	Records the key URIs in use for each Microsoft 365 Customer Key Data Encryption Policy (Exchange, SharePoint/OneDrive, Multi-Workload) and whether the availability key feature is set to "Keep" or "Remove" for each service
OnboardingService.Validate / Enable / Scenario	Steps to perform in the Microsoft 365 Customer Key onboarding service after reconfiguring keys, indicating which services to validate and enable (e.g. EXO, MDEP, SPO)

Each of these parameters should be predefined so that during a crisis, there is no ambiguity in values to use. Contoso maintains an up-to-date **parameter file** that can be quickly edited if needed (for example, to update the latest BackupFolder name) and then referenced by scripts to execute the DR process with minimal manual input, reducing the risk of human error under pressure.

Conclusion

Contoso's Azure Managed HSM Backup and Disaster Recovery plan provides a robust framework to ensure that cryptographic keys — which protect the organization's most sensitive data in Microsoft 365 — are never a single point of failure. By leveraging Azure's built-in capabilities (in a way consistent with Microsoft's own guidance) and by adhering to a well-defined runbook, Contoso achieves a resilient key management posture that balances high security and compliance with practical considerations of cost and complexity.

Key takeaways for stakeholders:

- The strategy **protects critical encryption keys** from loss, significantly reducing the risk of extended downtime or data inaccessibility in Microsoft 365 due to key unavailability.
- Operating in the **GCC High (Azure Government)** cloud ensures that all processes and data meet **FedRAMP High** and other government-mandated security controls. Contoso's approach underscores that compliance is not just about security in steady-state, but also about resilience — an expectation of frameworks like NIST SP 800-53 (Contingency Planning) and HIPAA's security rule for emergency access to electronic protected data.
- **Regular drills and updates** to the plan mean that if a real disaster occurs, Contoso's team can respond rapidly and effectively, having practiced the exact steps. This preparedness is vital in a high-stakes environment where every minute of downtime could impact healthcare operations or data security.

Relevant Microsoft Documentation & Best Practices:

- Microsoft's official **Managed HSM Disaster Recovery guide** outlines a similar approach of creating a new HSM, restoring the Security Domain, and then performing a full restore to recover keys. Contoso's runbook is closely aligned with this guidance and adapts it to the GCC High context.
- **Security Domain Management:** Background on the importance of safeguarding the Security Domain and recovery keys is available in Microsoft's documentation. Contoso follows these best practices by generating multiple key shares, storing them offline, and never relying on the HSM service itself to hold these critical materials.
- **Full Backup and Restore Procedures:** Microsoft Learn provides step-by-step tutorials on backing up and restoring Managed HSMs, confirming the necessity of a user-assigned identity and demonstrating Azure CLI for backup and restore operations, which Contoso has implemented in automation scripts.

- **FedRAMP High Controls:** Azure Government's services (including Key Vault and Managed HSM) are audited for FedRAMP High. The additional processes like offline backups and documented disaster recovery help meet controls such as CP-9 (Information System Backup) and CP-10 (Disaster Recovery Plan Testing) in the context of key management.

By following this comprehensive plan, Contoso can confidently operate Azure Managed HSM in a government cloud environment, providing encryption key availability and integrity even under duress. This ensures that Contoso's data always remains encrypted and accessible only to authorized users, protecting both the organization's operational continuity and its compliance posture.

This is a preliminary document and may be changed substantially prior to final commercial release of the software described herein.

The information contained in this document represents the current view of Microsoft Corporation on the issues discussed as of the date of publication. Because Microsoft must respond to changing market conditions, it should not be interpreted to be a commitment on the part of Microsoft, and Microsoft cannot guarantee the accuracy of any information presented after the date of publication.

This guide is for informational purposes only. Microsoft makes no warranties, express or implied, in this document.

Complying with all applicable copyright laws is the responsibility of the user. Without limiting the rights under copyright, no part of this document may be reproduced, stored in, or introduced into a retrieval system, or transmitted in any form or by any means (electronic, mechanical, photocopying, recording, or otherwise), or for any purpose, without the express written permission of Microsoft Corporation.

Microsoft may have patents, patent applications, trademarks, copyrights, or other intellectual property rights covering subject matter in this document. Except as expressly provided in any written license agreement from Microsoft, the furnishing of this document does not give you any license to these patents, trademarks, copyrights, or other intellectual property.

© 2020 Microsoft Corporation. All rights reserved.

The example companies, organizations, products, domain names, e-mail addresses, logos, people, places, and events depicted herein are fictitious. No association with any real company, organization, product, domain name, e-mail address, logo, person, place, or event is intended or should be inferred.

Microsoft, list Microsoft trademarks used in your white paper alphabetically are either registered trademarks or trademarks of Microsoft Corporation in the United States and/or other countries.

The names of actual companies and products mentioned herein may be the trademarks of their respective owners.